SYNAPSE-CRS · LABORATORY OBSERVER-ONLY CONTROL PLANE

Presentation Master Handbook

Grounded in repository source, API routers, Alembic migrations, frontend routes, and research reports. In-memory hotpatching is **not implemented**. Laboratory envelopes are not /proc telemetry. SAT is not host safety.

API 0.1.0 · Contracts 1.0.0 · Confidentiality: no secrets · University viva pack

Synapse-CRS Presentation Master Handbook

Audience: student speaker for a university viva.
Source presentations: NONE FOUND (no `.ppt`, `.pptx`, or presentation `.pdf` in the repository). This handbook is a **suggested 24-slide outline** derived from `README.md`, `docs/architecture/overview.md`, `docs/safety/claims.md`, `DEMO_RUNBOOK.md`, and implemented code. Do not tell the evaluator "this matches our original PPT" unless you bring your own file.

Laboratory live demo uses **constructed signed envelopes** through real ingest. **Not `/proc` telemetry.**

- Synapse-CRS Presentation Master Handbook
- How to use this book
- Slide 1 — Title: Synapse-CRS (observer-only research control plane)
- Slide 2 — What the system is and is not
- Slide 3 — Problem statement
- Slide 4 — Existing approaches and limits
- Slide 5 — Proposed system
- Slide 6 — Objectives (implemented)
- Slide 7 — System architecture
- Slide 8 — Technology stack
- Slide 9 — Frontend workspaces
- Slide 10 — Backend FastAPI
- Slide 11 — Database
- Slide 12 — Telemetry contract
- Slide 13 — Digital signatures (Ed25519)
- Slide 14 — Agent enrollment
- Slide 15 — Evidence correlation
- Slide 16 — Risk scoring formula
- Slide 17 — Neuro-symbolic reasoning
- Slide 18 — Hypotheses H1–H4
- Slide 19 — Z3 / Defence Lab
- Slide 20 — Threat graph
- Slide 21 — Audit integrity
- Slide 22 — Testing and research methodology
- Slide 23 — Limitations and future work
- Slide 24 — Conclusion
- Live demonstration script (laboratory envelopes)
- Cross-cutting speaking rules

How to use this book

For each slide: memorize **What to say** (~45–70 seconds). Use **Example** if asked to simplify. Use **Questions** as drill. Never skip **Mistakes**.

Slide 1 — Title: Synapse-CRS (observer-only research control plane)

Visible. Title, your name, “FastAPI + PostgreSQL + React investigation console”, version 0.1.0.
Bullets. Name expansion; observer-only; not a production SOAR.
Technical meaning. `API_VERSION = "0.1.0"`.
Why it matters. Sets honesty before architecture.
What to say. “Synapse-CRS is a laboratory control plane that registers authorized targets, stores signed telemetry, correlates evidence, and runs hybrid reasoning. The long product name mentions hotpatching; **that is not implemented**. Nothing in the API executes a host action.”
Example. Like a sealed evidence locker plus a reasoning notebook, not an antivirus that quarantines files.
Transition. “I’ll start with the problem this locker is meant to hold.”
Questions. Is this deployed in production? → No, lab/research.
Mistakes. Reading the full marketing name as a feature list.

Slide 2 — What the system is and is not

Visible. Two columns: DOES / DOES NOT (`docs/safety/claims.md`).
Bullets. Registry, cases, audit, ingest, correlation, hybrid, Z3-on-proposals vs zero-day, exploit, patch, eBPF.
Technical meaning. Claims file is backed by pytest.
Why it matters. Evaluators punish overclaim.
What to say. “I will only claim behaviour that has tests. Unauthenticated calls fail. Viewers cannot write. ACTION records executed false. SAT is not host safety.”
Example. A traffic light labelled VERIFICATION does not prove the intersection is safe.
Transition. “That discipline comes from the problem statement.”
Questions. Then why the hotpatching name? → Aspiration; not in this tree.
Mistakes. “We autonomously defend endpoints.”

Slide 3 — Problem statement

Visible. Spoofed telemetry; opaque ML; SIEM without enrollment; auto-mitigation risk.
Technical meaning. Ingest requires enrolled Ed25519; neural unusualness ≠ P(malicious).
Why it matters. Justifies signatures + H4.
What to say. “If anyone can POST events, investigations are fiction. If a model outputs 0.91, students call it 91% malware. We bind keys to targets and keep H4 when evidence is sparse.”
Example. Unsigned syslog from the internet.
Transition. “Existing tools don’t combine those constraints.”
Questions. Why not just use Splunk? → Next slide.
Mistakes. Attacking commercial vendors personally.

Slide 4 — Existing approaches and limits

Visible. SIEM, EDR, SOAR, generic ML IDS.
Bullets. SIEM: volume without enrollment proof. EDR: vendor agents. SOAR: playbooks that change hosts. ML IDS: accuracy theatre on CIC-IDS without the CSV.
Technical meaning. Phase 11 **fails closed** without `SYNAPSE_CICIDS_CSV`.
Why it matters. Differentiator is fail-closed honesty.
What to say. “We are not replacing a SIEM. We refuse to print CIC-IDS numbers we did not compute, and we refuse to isolate a host.”
Example. A paper with 99.9% on a missing dataset.
Transition. “Here is what we actually built.”
Questions. So you have no detection rate? → Synthetic Phase 10 only; say the numbers and the n=12 limit.
Mistakes. Claiming SIEM replacement.

Slide 5 — Proposed system

Visible. Operator → FastAPI → PostgreSQL; agent POST ingest; React console.
Technical meaning. Modular monolith; packages tested without HTTP.
Why it matters. Shows you know composition.
What to say. “One FastAPI process is the composition root. Policy, cases, audit, telemetry, correlation, and reasoning are importable packages. The UI never becomes the authorization boundary.”
Example. Like a compiler frontend and backend: UI is pretty-print of IR.
Transition. “Objectives were written to match tests.”
Questions. Why not microservices? → Single lab process, transactional audit with writes.
Mistakes. Drawing Kafka that isn’t there.

Slide 6 — Objectives (implemented)

Visible. Numbered objectives that match code.
Bullets. (1) Authz registry (2) Linear cases (3) Audit chain (4) Signed ingest (5) Correlation provenance (6) Hybrid + Z3-on-records (7) Honest UI.
What to say. Walk them as **done**, then say scientific evaluation of external datasets is **not done**.
Example. Objective 4 = `POST /api/v1/telemetry/ingest`.
Transition. “Architecture next.”
Questions. Which objective failed? → Independent DMBD trees / CIC-IDS.
Mistakes. Listing hotpatching as an objective achieved.

Slide 7 — System architecture

Visible. ASCII/block diagram from `docs/architecture/overview.md`.
Technical meaning. Request path: config fail-closed → bearer or signature → eligibility → write + audit hash.
What to say. “Health does not touch the DB. Ready runs SELECT 1. Control-plane writes need admin. Ingest authenticates the envelope, not a bearer.”
Example. Stolen viewer token cannot enroll an agent (403).
Transition. “Stack is deliberately boring.”
Questions. Where is Redis? → Not used.
Mistakes. Adding Kubernetes you didn’t run.

Slide 8 — Technology stack

Visible. Python 3.12, FastAPI, SQLAlchemy, Alembic, PostgreSQL 16, Pydantic, cryptography (Ed25519), Z3, React 19, Vite, TypeScript, React Flow, Vitest, pytest.
What to say. “Node is the console only. Alembic is a separate process so the API never holds migration credentials.”
Example. `create_app` raises if `MIGRATION_DATABASE_URL` is set.
Transition. “Frontend workspaces are distinct on purpose.”
Questions. Why React Flow? → Investigation canvas, not a dashboard widget.
Mistakes. “We used Bun/Next.js.”

Slide 9 — Frontend workspaces

Visible. Route table from `App.tsx`.
What to say. Name each route in one breath: Command, Telemetry, Evidence, Cases, Graph, Reasoning, Hypotheses, Defence, Research, Control, Session. Ctrl+K palette. DEMO vs LAB ENVELOPES vs LIVE.
Example. `/evidence?finding=` from Command Centre.
Transition. “Backend is the source of truth.”
Questions. Can the UI authorize admin? → No, 403 from API.
Mistakes. Demo fixtures as live telemetry.

Slide 10 — Backend FastAPI

Visible. Router files list.
What to say. “Routers live under `apps/api/src/synapse_api/routers/`. Errors are `{error: {code,message,details}}`. Docs at `/docs` unless environment is production.”
Example. Viewer POST `/targets` → 403 `authorization_failed`.
Transition. “Persistence next.”
Questions. REST delete target? → No delete routes.
Mistakes. Inventing GraphQL.

Slide 11 — Database

Visible. Table list: targets, cases, case_transitions, agents, telemetry_events, correlation_, *findings, reasoning_*, audit_events, audit_chain_state.
Technical meaning. Migrations 0001–0006; `synapse_app` GRANTs; append-only triggers.
What to say. “pytest uses `synapse_test`, not the demo `synapse` database. Application role cannot UPDATE audit rows.”
Example. `0005_correlation_findings.py`.
Transition. “How events enter.”
Questions. Can postgres superuser rewrite history? → Yes; we document that; verify still catches app-level edits.
Mistakes. “Tamper-proof blockchain.”

Slide 12 — Telemetry contract

Visible. Allowlisted types: `process_started`, `process_exited`, `network_connection_observed`.
Technical meaning. JSON Schema 1.0.0; redaction; sequence + boot_id.
What to say. “Unknown event types are rejected. There is no GET dump of telemetry; the console shows supporting events on findings.”
Example. Payload argv redaction tests.
Transition. “Then we sign it.”
Questions. Why not Sysmon XML? → Closed contract for v0.1.
Mistakes. “We ingest any JSON.”

Slide 13 — Digital signatures (Ed25519)

Visible. Domain string + canonical JSON + 64-byte signature Base64.
Technical meaning. `synapse-crs/telemetry-signature/1\n` + UTF-8 sorted JSON; `cryptography` Ed25519; public key 32 bytes hex on enroll.
What to say. “A valid signature proves the matching private key signed that exact envelope. It does **not** prove the agent is allowed on the target — enrollment does.”
Example. Flip one JSON key → verify fails.
Transition. “Enrollment binds the key.”
Questions. Why not JWT? → Detached signature over canonical envelope, not a session token.
Mistakes. “Ed25519 encrypts the event.”

Slide 14 — Agent enrollment

Visible. Admin POST agents with `public_key_hex`; status active/revoked; key_generation.
What to say. “Only eligible targets receive agents. Rotation increments generation. Revocation is one-way. The Linux collector in `packages/agent` polls procfs when configured; our live demo ingested **laboratory envelopes**, not a recorded `/proc` capture.”
Example. Fingerprint `sha256:` of the public key.
Transition. “Stored rows become findings.”
Questions. Can a revoked key ingest? → Should fail enrollment checks (say: enrolled+active required).
Mistakes. Equating enrolled with currently connected.

Slide 15 — Evidence correlation

Visible. Process identity tuple; finding types table.
Technical meaning. PID is never the join key. Epistemic `correlation` vs `inference`.
What to say. “We join on agent, boot, pid, **and** start_ticks. An exit without start is an inference, labelled, not turned into a fake start event.”
Example. `lifecycle_exit_without_start`.
Transition. “Those findings roll into a heuristic score.”
Questions. Is this MITRE mapping? → No, research heuristics.
Mistakes. “We detected APT29.”

Slide 16 — Risk scoring formula

Visible.

[R = \min\left(100, \sum_g \min(raw_g, cap_g)\right)]

Variables. (raw_g) sum of finding contributions in group (g); caps 30/50/20/20/20/15 as in `scoring.py`.
Why. Attention heuristic, not P(compromise).
Worked example. One exit-without-start (15) + repeated network raw 8 cap 20 + multi-port raw 20 cap 20 → (R=\min(100,15+8+20)=43) (matches a live lab run in this project). Severity 40–69 = medium.
Cannot prove. Host is compromised or safe.
What to say. “High means the heuristic asked for attention.”
Transition. “Reasoning sits on top of this evidence.”
Mistakes. “43% malware.”

Slide 17 — Neuro-symbolic reasoning

Visible. Pipeline: reconstruct → features → Isolation Forest unusualness → rules → hybrid select → explanation.
Technical meaning. Engine 0.6.0; model id `isolation-forest-synthetic-baseline-v1`; unusualness **not** a probability.
What to say. “Neural answers ‘is this unusual versus a synthetic baseline?’ Symbolic answers ‘which inspectable rule fired?’ Hybrid picks H1–H4 conservatively.”
Example. Unusualness 0.12 below threshold → not unusual.
Transition. “Selection rule is the viva favourite.”
Questions. Ablation = causality? → No, documented limitation.
Mistakes. “Our neural net detects zero-days.”

Slide 18 — Hypotheses H1–H4

Visible. H1_normal, H2_unusual_legitimate, H3_suspicious_pattern, H4_insufficient_evidence.
Technical meaning. If completeness < 0.4 or <2 observations, H4 support ≥ 0.85; ties prefer H4 (`hybrid.py`).
What to say. "**H4 means we refuse to call it an attack.** That is a feature. Support 0.8 is an engine score."
Example. Live lab assessment selected H4.
Transition. "Even a strong hypothesis cannot execute."
Questions. Why not softmax probabilities? → Scores are not calibrated; we refuse that language.
Mistakes. "H4 means false negative."

Slide 19 — Z3 / Defence Lab

Visible. Policy conjunction; SAT/UNSAT/UNKNOWN.
Formula. (\neg executed \land \neg destructive \land authorized \land in_scope \land identity_certain \land evidence_present \land (impactful \rightarrow human_approved) \land \neg mitigation_kind).
Timeout. 2000 ms.
What SAT proves. There exists an assignment satisfying **those Booleans**, not that a Linux host is safe.
What to say. “If identity is not certain, we expect UNSAT. Kind `execute_host_mitigation` is forbidden in this phase.”
Example. Violated `identity_certain`.
Transition. “Operators still need a graph of what we *did* store.”
Questions. Why Z3 not a Python if? → Inspectable solver result + timeout unknown.
Mistakes. “Z3 proved the server secure.”

Slide 20 — Threat graph

Visible. React Flow nodes: target, agent, finding, event.
What to say. “Edges are only enrollment, finding support, or stored correlation rule ids. We do not invent process parent edges.”
Example. Click finding → Evidence Lab.
Transition. “Integrity of the story is the audit chain.”
Questions. Graph DB? → No, client layout of REST snapshot.
Mistakes. “Real-time packet radar.”

Slide 21 — Audit integrity

Visible. (h_i = \mathrm{SHA256}(canonical(e_i \parallel h_{i-1}))), (h_0 = 0^{64}).
What to say. “`GET /api/v1/audit/verify` replays the chain. App role cannot UPDATE events. A superuser can still disable triggers — we say that in the claims doc.”
Example. `valid=true`, n=17 in the lab seed.
Transition. “How we tested this.”
Questions. Blockchain? → Hash chain in PostgreSQL, not a consensus network.
Mistakes. “Immutable forever.”

Slide 22 — Testing and research methodology

Visible. pytest integration; vitest; Phase 10 n=12 synthetic; Phase 11–13 fail-closed.
Numbers (synthetic only). Hybrid 3-class accuracy 1.0 on 12 reconstructions; neural-only 0.3333 because it cannot emit insufficient; CIC-IDS available false (`docs/research/benchmark-results.md`).
What to say. “**n=12 constructed rows cannot generalize.** We report fail-closed when corpora are missing instead of fabricating scores.”
Transition. “Limitations, then a live walkthrough.”
Questions. Why accuracy 1.0? → Tiny labelled synthetic set; rules+hybrid match labels by construction — say that first.
Mistakes. Leading with 100% accuracy.

Slide 23 — Limitations and future work

Visible. No mitigation; no hotpatch; no OIDC; no telemetry GET list; no independent trees; tokens are shared secrets.
What to say. “Future work is OIDC, real procfs captures on owned hosts, operator-supplied CIC-IDS/DMBD, never silent mitigation.”
Transition. “I’ll demonstrate the console on laboratory envelopes.”
Questions. When will you hotpatch? → Not until a version with tests and a narrower claim; not this viva.
Mistakes. Promising a production EDR date.

Slide 24 — Conclusion

Visible. One sentence + demo reminder.
What to say. “Synapse-CRS is an honest observer: signed evidence, explainable correlation, conservative hypotheses, policy SAT on records, and an audit chain — with labelled synthetic limits.”
Questions. What is your biggest limitation? → Scientific generalization and no execution by design.
Mistakes. Ending on “fully autonomous cyber defense.”

Live demonstration script (laboratory envelopes)

Assume HUD shows **LAB ENVELOPES**, `API live`, `DB ready`, target `live-lab-host` (or your seeded name). If API is down, use **Demonstration mode** and say “browser fixtures, not the database.”

Step	Click	Show	Say	Expect	If empty
1 Command	`/`	Core, meters, tape	“Spatial overview; source live; not a packet radar.”	Agents ≥0, findings if seeded	“No snapshot; I’ll use demo and label it.”
2 Target	Target lock → Telemetry	Channel, fingerprint	“Enrolled is not connected. Ticker is finding.supporting_events, not GET telemetry.”	Agent status active	“No agents enrolled.”
3 Findings	Open evidence lab	Explorer	“Epistemic correlation vs inference.”	Finding types	Run admin correlation (don’t pretend).
4 Evidence	Event row	Inspector + storyline	“Missing evidence stays missing.”	Classifications	Timeline none.
5 Graph	Threat graph	Nodes	“Only stored edges.”	Layout	“No graphable entities.”
6 Reasoning	Hybrid stage	H4 text	“Support is not a probability. H4 refuses malice.”	dataset_label synthetic_lab	“No assessment POST yet.”
7 Hypotheses	Left/right	Contradicts	“Competing explanations from one payload.”	Four ids	Same.
8 Defence	Solver line	SAT copy	“UNSAT ⇏ unsafe host; SAT ⇏ safe host.”	constraints	No verification object.
9 Audit	Control	valid=true	“Replay SHA-256 chain.”	n events	Chain not loaded.
10 Research	Observatory	not_completed	“I will not claim CIC-IDS success.”	seals	Static page always works.

Cross-cutting speaking rules

1. Never say “we patch memory.”
2. Never say “91% confident it’s malware.”
3. Never say laboratory envelopes are `/proc`.
4. Never say SAT proved the machine safe.
5. If you don’t remember an endpoint, say you’ll check OpenAPI `/docs` — don’t invent GET `/telemetry/events`.